

PARA O ALTO E AVANTE

GERENCIAMENTO DE LOGS



9

LISTA DE FIGURAS

Figura 1 – Exemplo de <i>log</i>	7
Figura 2 – Logs de software de segurança	11
Figura 3 – Log de sistema operacional	13
Figura 4 – Log do Apache	15

EXEMPLO

LISTA DE TABELAS

Tabela 1 – Ferramentas para análise de log.....	21
---	----

EMSE

SUMÁRIO

1 GERENCIAMENTO DE LOGS.....	5
2 LOGS DE SEGURANÇA.....	6
2.1 Softwares de segurança.....	9
2.2 Sistemas operacionais	11
2.3 Aplicações	13
2.4 Gerenciamento de logs	15
3 DESAFIOS DO GERENCIAMENTO DE LOGS	17
3.1 Geração e armazenamento de logs	17
3.2 Proteção de logs	19
3.3 Análise de logs	20
4 BOAS PRÁTICAS	21
CONCLUSÃO.....	23
REFERÊNCIAS.....	24

1 GERENCIAMENTO DE LOGS

Convivemos com diversos tipos de aplicações em nosso dia a dia, seja um software de e-mail, um editor de texto, um navegador web, uma rede social ou até mesmo um monitor de batimentos cardíacos no seu *smartwatch*. Independentemente da finalidade, todas essas aplicações geram *logs* para ajudar no diagnóstico de problemas na própria aplicação ou simplesmente para monitorar o seu uso. O problema é que o formato dos arquivos de *logs* não é padronizado e, quando é necessário correlacionar esses *logs*, exige-se um grande esforço manual ou o uso de uma ferramenta automatizada.

Imagine uma organização que possui diversos sistemas de fornecedores diferentes, distribuídos em vários servidores (cenário bastante comum), que analisa os inúmeros logs gerados diariamente. É uma tarefa um tanto quanto complexa!

Um *log* é um registro dos eventos ocorridos em um sistema e/ou rede de computadores. Arquivos de *logs* podem conter registros do desempenho do sistema, transações, registros de intrusão, registros de usuários, bancos de dados, entre tantos outros tipos de informações geradas. *Logs* nada mais são do que dados.

Originalmente, os *logs* eram usados para a resolução de problemas em sistemas, mas hoje servem para muitas outras funções, como otimização de sistema, desempenho de redes, registro das ações dos usuários e fornecimento de dados úteis para a investigação de atividades maliciosas. Os registros evoluíram para conter informações relacionadas a muitos tipos de eventos diversos que ocorrem nas redes e nos sistemas.

Os arquivos de *logs* são muito importantes, pois, a partir deles, é possível analisar a visibilidade da estrutura de Tecnologia da Informação (TI). Com base nos registros gerados pelos *logs*, é plausível identificar eventos que ocorrem no ambiente de TI e, dessa forma, analisar, verificar, entender e corrigir possíveis falhas.

O gerenciamento de *logs* é utilizado para lidar com grandes volumes de dados desde autenticações até modificações. Essa administração é importante para garantir a segurança da informação, por isso a recomendação é que fiquem armazenados por um período (dias, meses ou anos), para, a partir deles, ser possível identificar ameaças à rede e comportamentos indesejados. O registro de *logs* pode

conter uma grande variedade de dados sobre os eventos que ocorrem nos sistemas e nas redes, como um *log* de auditoria para rastrear a autenticação de um usuário ou *logs* de segurança de firewall para registrar possíveis ataques.

Em razão da grande quantidade de dispositivos de rede, servidores, estações de trabalho, Internet das Coisas (IoT) e o número cada vez maior de ameaças contra esses sistemas, o volume e a variedade de *logs* de segurança aumentaram consideravelmente, criando a necessidade de gerenciar melhor os logs de segurança para manter o ambiente de TI protegido. Entende-se como gerenciamento de *logs* o processo de geração, transmissão, armazenamento, análise e descarte de dados de registro de *logs*.

2 LOGS DE SEGURANÇA

Os *logs* são fontes ricas de informação e descrevem eventos registrados por dispositivos ou aplicações, podendo conter diferentes níveis de detalhamento de informações. Um *log* não é muito diferente de um arquivo ou tabela. Um arquivo é um arranjo de bytes, uma tabela é um arranjo de registros e um *log* é apenas um tipo de tabela ou arquivo em que os registros estão classificados por tempo (KREPS, 2014). Esse conjunto de registros classificados por tempo, que suporta apenas inserção, representa os eventos que aconteceram em um sistema ou rede.

Geralmente, os *logs* podem ser utilizados para responder questões relacionadas a eventos passados, como: identificar tentativas de acesso sem sucesso, instante em que o sistema sofreu instabilidade e informar que o sistema de arquivo está sobrecarregado. No entanto, *logs* podem ser usados não apenas para revelar informações passadas, mas sim para identificar possíveis falhas futuras. Por exemplo, eles podem identificar que aplicações estão sendo exploradas, permitindo à equipe avaliar se as suas proteções de segurança são adequadas (CERON, 2014). Também são utilizados para a produção de relatórios, a fim de monitorar acessos a websites, uso de e-mail, consumo de banda, aplicações bloqueadas, etc.

Entretanto, identificar informações relevantes em um arquivo de *log* é uma tarefa complexa e lenta, principalmente em sistemas com um grande volume de dados. Segundo Chuvakin et al. (2012), uma análise de *log* eficaz também requer co-

nhecimento de seu ambiente. Você precisa saber o que é bom e o que é ruim para a sua rede e o que é suspeito e o que é normal.

Apesar de não haver uma padronização em mensagens de *logs* (cada fabricante ou dispositivo usa um formato), existem alguns elementos essenciais presentes em toda mensagem de *log*:

- **Timestamp:** data/hora que o evento foi registrado.
- **Origem:** o sistema que originou a mensagem. Geralmente um endereço IP ou nome do *host*.
- **Dados:** informações sobre o evento gerado. Apesar de não haver uma padronização, pode conter: dados de usuários, dados de aplicações, recursos de sistemas, entre outros elementos.

No exemplo, é possível visualizar um *log* em formato de texto do firewall Fortigate. Uma das primeiras informações presentes no registro é o *timestamp* (**date=2020-02-02 time=17:46:36**); depois temos as informações de qual dispositivo originou o evento (**devname=FG-TESTE devid=FGT60E**) e, nos dados do evento, é possível verificar que se trata de uma tentativa de intrusão via HTTP, que foi bloqueada, com origem no IP 219.155.209.156 proveniente da China (conforme destacado em amarelo).

Message meets Alert condition

The following intrusion was observed: "Dasan.GPON.Remote.Code.Execution".

```
date=2020-02-02 time=17:46:36 devname=FG-TESTE devid=FGT60E logid="0419016384"
type="utm" subtype="ips" eventtype="signature" level="alert" vd="root"
eventtime=1580676396 severity="critical" srcip=219.155.209.156 srccountry="China"
dstip=192.168.2.10 srcintf="wan2" srcintfrole="wan" dstintf="internal" dstintfrole="lan" ses-
sionid=645764 action="dropped" proto=6 service="HTTP" policyid=6 at-
tack="Dasan.GPON.Remote.Code.Execution" srcport=60221 dstport=8081 host-
name="127.0.0.1:80" url="/GponForm/diag_Form?images/" direction="outgoing" at-
tackid=46083 profile="default" ref="http://www.fortinet.com/ids/VID46083" incidentserial-
no=632457804 msg="applications3: Dasan.GPON.Remote.Code.Execution," crscore=50
crlevel="critical"
```

Figura 1 – Exemplo de *log*
Fonte: Elaborado pelo autor (2020)

Os sistemas de *log* – registros de eventos e notificações – são compostos de diferentes elementos responsáveis por gerar, transmitir e armazenar informações de eventos. Os mais comuns são:

- **Syslog:** protocolo aberto baseado em UDP, sendo o mais comum mecanismo de *log*.
- **Simple Network Management Protocol (SNMP):** utilizado para gerenciamento de redes.
- **Windows Event Log:** formato proprietário da Microsoft, presente na maioria dos dispositivos que utilizam a plataforma Windows.
- **Banco de dados:** algumas aplicações usam base de dados remota para armazenar informações de *log* de maneira estruturada.
- **Protocolos proprietários:** alguns sistemas e aplicações implementam protocolos customizados, até mesmo criptografados, para transferir e coletar informações de eventos. Exemplo: a Fortinet, fornecedora de soluções de segurança, com o Security Fabric e o protocolo FortiTelemetry.

Alguns *logs* são mais propensos do que outros a registrar informações úteis em diferentes situações, como detecção de ataques, fraude e uso impróprio. Dependendo do tipo de situação, certos logs são normalmente os mais prováveis de conter informações detalhadas sobre a atividade em questão. Outros registros geralmente contêm informações menos detalhadas e são úteis apenas para correlacionar eventos registrados nos tipos de registros primários. Por exemplo, os *logs* de um *switch* gerenciável (L3) ou *access point* bem como programas de monitoramento de rede (network scanner) contêm registros de eventos que podem ser usados para auditoria e análise forense. Outro exemplo é o de um sistema de detecção de intrusão (IDS), que pode registrar comandos maliciosos emitidos para um servidor de um *host* externo; esta seria uma fonte primária de informações de ataque. Um gerenciador de incidentes pode, então, revisar um log de firewall para procurar outras tentativas de conexão do mesmo endereço IP de origem; esta seria uma fonte secundária de informações de ataque.

Segundo NIST (2006), em seu livro *Guide to Computer Security Log Management*, os tipos de *logs* mais importantes em termos de cibersegurança são providos de:

- Softwares de segurança (antivírus, firewall, etc.);
- Sistemas operacionais (Windows, Linux e Mac);

- Aplicações.

É importante considerar o valor potencial de cada fonte de dados de *log* ao projetar e implementar uma infraestrutura de gerenciamento de *logs*.

2.1 Softwares de segurança

A maioria das organizações usa vários tipos de softwares de segurança baseados em rede e *host* para detectar atividades maliciosas, proteger dados, sistemas e apoiar o time de tratamento e resposta a incidentes (CSIRT). Assim, os softwares de segurança são a principal fonte de dados de eventos de cibersegurança. Os tipos comuns de software de segurança baseado em rede e *host* incluem:

- **Software Antimalware:** forma mais comum de software *antimalware* é o antivírus, que normalmente registra todas as atividades de um *malware* detectado, tentativas de desinfecção de arquivos e sistemas, bem como arquivos em quarentena. Além disso, o antivírus também pode registrar quando as varreduras de *malware* foram executadas e em que momento ocorreu a atualização de assinaturas de antivírus ou de software. *Antispyware* e outros tipos de software *antimalware* (por exemplo, detectores de *rootkit*) também são fontes comuns de informação de segurança.
- **Sistemas de detecção e prevenção de intrusões:** detectam a tentativa de intrusão a sistemas e registram informações detalhadas sobre comportamentos suspeitos e ataques detectados, bem como quaisquer ações que os sistemas de prevenção de intrusão executem para impedir a atividade maliciosa em andamento. Alguns sistemas de detecção de intrusão, como software de verificação de integridade de arquivo, são executados periodicamente.
- **Softwares de acesso remoto:** o acesso remoto normalmente é concedido e protegido por meio de uma Virtual Private Network (VPN). Os sistemas VPN registram tentativas de login bem-sucedidas e malsucedidas, como as datas e o horário que cada usuário ficou conectado e desconectado e a quantidade de dados enviados e recebidos em cada sessão de usuário. Sistemas VPN que suportam controle de acesso granular, como muitas

VPNs SSL (*Secure Sockets Layer*), podem inclusive registrar informações detalhadas a respeito do uso de recursos (páginas web navegadas, arquivos abertos/copiados, etc.).

- **Web Proxies:** são *hosts* intermediários por meio dos quais os sites da web são acessados. *Web proxies* fazem solicitações de páginas da web em nome dos usuários e armazenam em *cache* cópias da página solicitada, para tornar os acessos adicionais a essas páginas mais eficientes. Os *Web proxies* também podem ser usados para restringir o acesso à web e adicionar uma camada de proteção entre clientes e servidores web. Eles geralmente mantêm um registro de todas as URLs acessadas por meio deles.
- **Software de gerenciamento de vulnerabilidades:** inclui software de gerenciamento de *patch* (correções de segurança) e software de avaliação de vulnerabilidade. Normalmente registram o histórico de instalação de *patch* e o status de vulnerabilidade de cada *host*, que inclui vulnerabilidades conhecidas e se as atualizações de software estão pendentes. O software de gerenciamento de vulnerabilidades também pode registrar informações sobre as configurações dos *hosts*.
- **Servidores de autenticação:** incluindo servidores de diretório (LDAP) e de login único (SSO), registram cada tentativa de autenticação, contendo sua origem, nome de usuário, sucesso ou falha e data/hora.
- **Roteadores (*routers*):** os roteadores podem ser configurados para permitir ou bloquear diversos tipos de tráfego na rede com base em uma política. Roteadores que bloqueiam o tráfego são geralmente configurados para registrar apenas atividades suspeitas.
- **Firewalls:** assim como os roteadores, os firewalls permitem ou bloqueiam atividades com base em uma política criada pela organização, no entanto, os firewalls usam métodos muito mais sofisticados para examinar o tráfego da rede. Eles também podem rastrear todo o tráfego e realizar inspeção de conteúdo. Firewalls tendem a ter políticas mais complexas e gerar registros de atividades mais detalhados do que os roteadores.

- **Sandbox (servidores de quarentena de rede):** algumas organizações verificam o comportamento de segurança de cada pacote de rede remoto antes de permitir que ele se conecte à rede. Isso geralmente é feito por meio de um servidor de Sandbox e agentes colocados em cada *host*. *Hosts* que não respondem às verificações do servidor ou que falham nas verificações são colocados em quarentena em um segmento de rede local virtual (VLAN) separado. Servidores de sandbox registram informações sobre o status das verificações, incluindo quais *hosts* ficaram em quarentena e por quais motivos.

Na Figura “Logs de software de segurança” é possível visualizar alguns exemplos de *logs* de software de segurança.

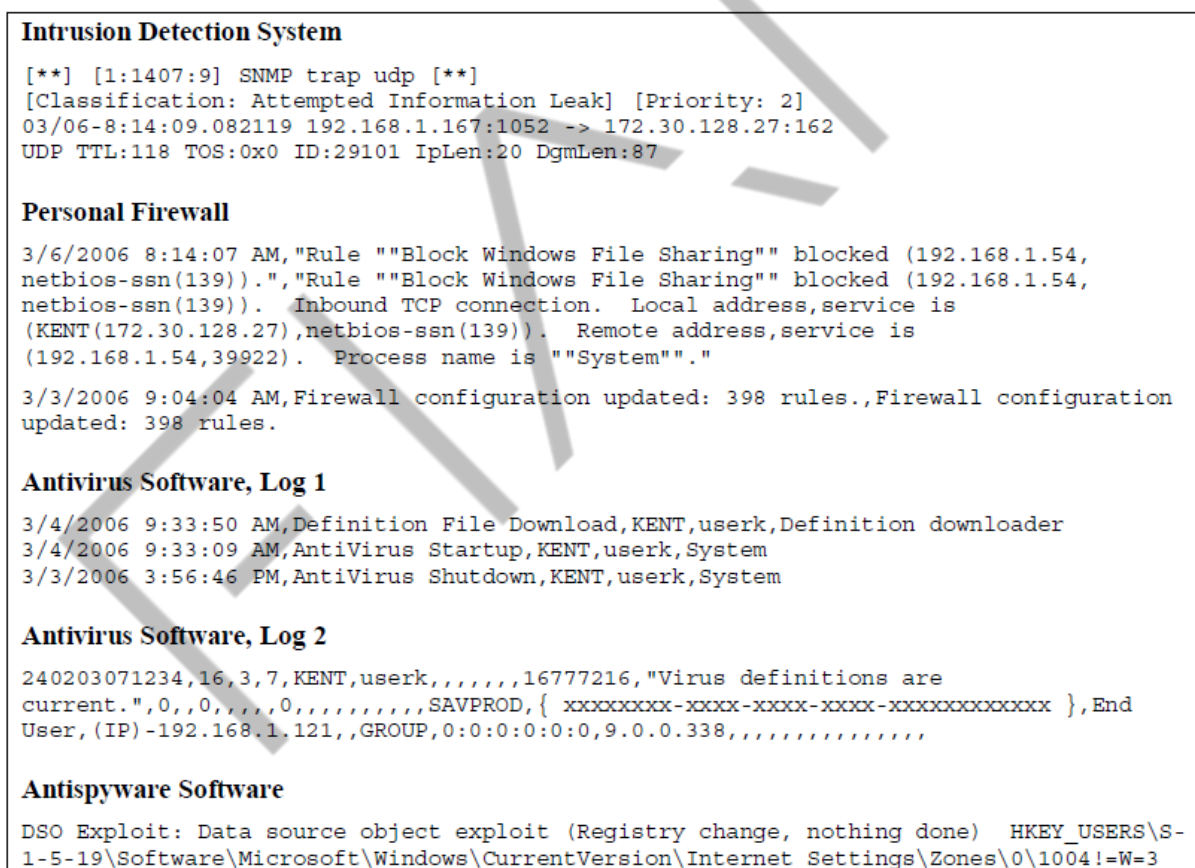


Figura 2 – Logs de software de segurança

Fonte: NIST (2006)

2.2 Sistemas operacionais

Sistemas Operacionais (SO) para servidores, estações de trabalho e dispositivos de rede geralmente registram uma variedade de informações referentes à se-

gurança. Os tipos mais comuns de dados do sistema operacional relacionados à segurança são os seguintes:

- **Eventos do sistema:** são ações operacionais realizadas por componentes do sistema operacional, como encerrar o sistema ou iniciar um serviço. Normalmente, eventos com falhas e eventos significativos são registrados, mas muitos sistemas operacionais permitem que os administradores especifiquem quais tipos de eventos serão registrados. Os detalhes registrados de cada evento também variam amplamente; em geral, cada um contém carimbo de data/hora e outras informações de apoio, como status e códigos de erro, nome do serviço e usuário ou conta do sistema associada a um evento.
- **Registros de auditoria:** contêm informações de eventos de segurança, como sucesso e falha em tentativas de autenticação, acessos a arquivos, mudanças na política de segurança, alterações na conta (por exemplo: criação, exclusão e atribuição de privilégios de conta) e uso de privilégios. Os sistemas operacionais normalmente permitem que administradores de sistema especifiquem quais tipos de eventos devem ser auditados e se são tentativas bem-sucedidas e/ou fracassadas de realizar certas ações, as quais devem ser registradas.

Os *logs* do sistema operacional são mais benéficos para identificar ou investigar atividades suspeitas envolvendo um determinado *host*. Segundo Chuvakin et al. (2012), ocasionalmente, os registros podem refutar outras evidências, o que por si só pode indicar que outras fontes foram corrompidas.

Depois que a atividade suspeita é identificada pelo software de segurança, os *logs* do sistema operacional são frequentemente consultados para se obter mais informações sobre a atividade. Por exemplo, um dispositivo de segurança de rede pode detectar um ataque contra um *host* particular; os *logs* do sistema operacional desse *host* podem indicar se um usuário estava conectado ao *host* no momento do ataque e se o ataque foi bem-sucedido.

Na Figura “Log de sistema operacional”, é possível observar um *log* de auditoria do Windows do computador de nome KENT.

```
Event Type:   Success Audit
Event Source: Security
Event Category: (1)
Event ID:     517
Date:         3/6/2006
Time:         2:56:40 PM
User:         NT AUTHORITY\SYSTEM
Computer:     KENT
Description:
The audit log was cleared
Primary User Name: SYSTEM      Primary Domain: NT AUTHORITY
Primary Logon ID: (0x0,0x3F7)  Client User Name: userk
Client Domain: KENT           Client Logon ID: (0x0,0x28BFD)
```

Figura 3 – Log de sistema operacional
Fonte: NIST (2006)

2.3 Aplicações

Os sistemas operacionais e softwares de segurança fornecem a base e proteção para os aplicativos, que são usados para armazenar, acessar e manipular os dados usados em processos de negócios da organização. A maioria das organizações conta com uma variedade de aplicativos comerciais prontos para uso, como servidores de e-mail, servidores web, navegadores web, servidores de arquivos, compartilhamento de arquivos, servidores de banco de dados, entre outros, além de aplicativos de negócios, como sistemas de gestão empresarial (ERP), sistemas de relacionamento com o cliente (CRM), sistemas logísticos (*supply chain*), sistemas financeiros e alguns outros desenvolvidos para uso próprio. Certos aplicativos geram seus próprios arquivos de *logs*, enquanto outros usam os recursos de *log* do sistema operacional em que estão instalados.

Os aplicativos variam significativamente nos tipos de informações que registram:

- **Solicitações do cliente e respostas do servidor**, que podem ser muito úteis na reconstrução de sequências de eventos e na determinação de seu resultado. Se o aplicativo registrar o usuário com sucesso, geralmente é possível determinar qual usuário fez cada solicitação. Algumas aplicações podem detalhar melhor o evento, como servidores de e-mail que gravam o remetente, o destinatário, o assunto e o nome dos anexos de cada e-mail; servidores web gravam o endereço (URL) de cada página acessada e a resposta do servidor, enquanto aplicações de negócio, como sistemas financeiros, gravam o que cada usuário acessou. Essas informações podem

ser usadas para identificar ou investigar incidentes com o propósito de auditoria e compliance.

- **Informações da conta**, como tentativas de autenticação bem-sucedidas e malsucedidas, alterações de conta e usos de privilégios. Além de identificar eventos de segurança, como tentativa de descoberta de senhas (*brute force*) e escalonamento de privilégios, esse recurso pode ser usado para identificar quando e quem usou o aplicativo.
- **Informações de uso**, como o número de transações que ocorrem em um determinado período (minuto, hora) e o tamanho das transações (tamanho da mensagem de e-mail e tamanho da transferência de arquivo). Isso pode ser útil para certos tipos de monitoramento de segurança, como prevenção de perda de dados (DLP).
- **Ações operacionais significativas**, como inicialização e desligamento de aplicativos, falhas de aplicativos e mudanças importantes na configuração do aplicativo. Isso pode ser usado para identificar equipamentos comprometidos e falhas operacionais.

Muitas dessas informações, especialmente para aplicativos que não são usados por meio de rede não criptografada, só podem ser registradas pelos aplicativos, o que torna os registros particularmente valiosos para incidentes de segurança relacionados a aplicativos, auditoria e esforços de conformidade. No entanto, com frequência, esses registros estão em formatos proprietários que dificultam seu uso, sendo necessários mais recursos para revisar seu conteúdo.

Na Figura “Log do Apache”, vemos um *log* do servidor Apache durante um ataque HTTP Flood, em que o atacante manipula solicitações indesejadas (HTTP e GET) para provocar uma negação de serviço (DoS) no servidor web, a fim de causar sua indisponibilidade.

```
10.201.1.100 - - [14/Nov/2013:17:58:13 -0300] "GET / HTTP/1.1" 200 603 "-" "Mozilla/5.0 (Windows; NT 5.1; en-GB; rv:1.9.2.17) Gecko/20110420 Firefox/3.6.17"
10.201.1.104 - - [14/Nov/2013:17:58:13 -0300] "GET / HTTP/1.1" 200 603 "-" "Mozilla/5.0 (Windows; NT 6.0; en-GB; rv:1.9.2.17) Gecko/20110420 Firefox/3.6.17"
10.201.1.104 - - [14/Nov/2013:17:58:13 -0300] "GET / HTTP/1.1" 200 603 "-" "Mozilla/5.0 (Windows; NT 5.1; pt-PT; rv:1.9.2.17) Gecko/20110420 Firefox/3.6.17"
172.30.1.5 - - [14/Nov/2013:17:58:13 -0300] "GET /home/pss2008/Editais/Edital02_2008.htm HTTP/1.1" 200 603 "-" "Wget/1.13.4 (linux-gnu)"
172.30.1.4 - - [14/Nov/2013:17:58:13 -0300] "GET /home/pss2013/Concorrenciaa.pdf HTTP/1.1" 200 603 "-" "Wget/1.13.4 (linux-gnu)"
10.201.1.104 - - [14/Nov/2013:17:58:13 -0300] "GET / HTTP/1.1" 200 603 "-" "Mozilla/5.0 (Windows; NT 5.1; pt-PT; rv:1.9.2.17) Gecko/20110420 Firefox/3.6.17"
10.201.1.100 - - [14/Nov/2013:17:58:13 -0300] "GET / HTTP/1.1" 200 603 "-" "Mozilla/5.0 (Windows; NT 5.1; en-GB; rv:1.9.2.17) Gecko/20110420 Firefox/3.6.17"
10.201.1.104 - - [14/Nov/2013:17:58:13 -0300] "GET / HTTP/1.1" 200 603 "-" "Mozilla/5.0 (Windows; NT 5.1; pt-PT; rv:1.9.2.17) Gecko/20110420 Firefox/3.6.17"
```

Figura 4 – Log do Apache
Fonte: ResearchGate (2020)

Os administradores de sistemas (*sysadmin*) devem estar cientes da confiabilidade de cada fonte de *log*. Fontes de *log* que não são seguras, incluindo mecanismos de transporte inseguros, são mais suscetíveis a mudanças de configuração e a alterações. Os administradores devem tomar cuidado adicional para determinar a precisão de *logs* de *host* que sofreram ataques bem-sucedidos, como também examinar outros *logs*.

2.4 Gerenciamento de logs

O gerenciamento de *log* pode beneficiar uma organização de diversas formas. Ele ajuda a garantir que os registros de segurança sejam armazenados com detalhes suficientes por um período apropriado. As revisões e análises de *log* de rotina são benéficas para identificar incidentes de segurança, violações de políticas, atividades fraudulentas e problemas operacionais logo após sua ocorrência e para fornecer informações úteis a fim de resolver esses problemas. Os registros também podem ser úteis para realizar auditorias e análises forenses, apoiando as investigações internas da organização, estabelecendo linhas de base e identificando tendências operacionais e problemas de longo prazo.

Além dos benefícios inerentes do gerenciamento de *logs*, uma série de leis e regulamentos obrigam as organizações a armazenar e revisar certos *logs*. A seguir, há uma lista dos principais regulamentos, padrões e diretrizes que ajudam a definir as necessidades das organizações para gerenciamento de *log*:

- **Lei americana Sarbanes-Oxley (SOX):** embora a SOX se aplique principalmente a práticas financeiras e contábeis, ela também abrange as funções de TI que dão suporte a essas práticas. Essa lei pode ser apoiada pela frequente revisão de *logs* em busca de sinais de violações de segurança, incluindo exploração, retenção e registros de revisões de *log*, para análise futura realizada por auditores.
- **PCI DSS (padrão de segurança de dados da indústria de cartões de pagamento):** se aplica a organizações que armazenam, processam ou transmitem dados do portador do cartão de crédito. Um dos requisitos do PCI DSS é rastrear todo o acesso aos recursos da rede e aos dados do titular do cartão.
- **Marco Civil da Internet (Lei nº 12.965/2014):** regula o uso da Internet no Brasil. Prevê, também, que administradores de sistemas autônomos (provedores de Internet) são obrigados a guardar *logs* de conexão por um período de um ano, com data e hora de início e término de uma conexão, a duração e o endereço IP utilizado pelo terminal para o envio e o recebimento de pacotes de dados.
- **Lei Geral de Proteção de Dados (Lei nº 13.709/2018):** entrou em vigor em setembro de 2020 e prevê uma série de direitos ao titular do dado, bem como diversos deveres às organizações que tratam os dados da pessoa natural (pessoa física). Para se manter em conformidade com a lei e evitar as penalidades (multa de até 2% do faturamento do grupo econômico), é importante manter e gerenciar os *logs* das diversas aplicações e sistemas utilizados na organização.

As organizações devem estabelecer processos operacionais de gerenciamento de *logs*. Os principais processos normalmente incluem a configuração de fontes de *logs*, realizando análise de *logs*, iniciando respostas a eventos identificados e gerenciando armazenamento de longo prazo. Os administradores de sistemas têm como responsabilidades:

- Monitorar o registro de todas as fontes;
- Monitorar a rotação de registros e os processos de arquivamento;

- Verificar atualizações e *patches* para software de registro, aquisição, teste e implantação;
- Garantir que cada host de registro de *log* esteja sincronizado com um servidor de tempo (NTP) comum;
- Reconfigurar o registro conforme necessário, com base em mudanças de política, tecnologia, entre outros fatores;
- Documentar e relatar anomalias nas configurações e nos processos de *logs*.

3 DESAFIOS DO GERENCIAMENTO DE LOGS

Muitas organizações enfrentam desafios semelhantes relacionados ao gerenciamento de *log*, todas lidando com o mesmo dilema: como equilibrar efetivamente uma quantidade limitada de recursos de gerenciamento de *log* diante de um fluxo de dados de registro em constante crescimento. Vamos discutir os tipos de desafios mais comuns, divididos em três grupos: geração e armazenamento, proteção e análise de *logs*.

3.1 Geração e armazenamento de logs

Em uma organização típica, muitos sistemas operacionais de *hosts*, software de segurança e outros aplicativos geram e armazenam histórico. Isso complica o gerenciamento de *logs* por diversos fatores:

- **Muitas fontes:** os registros estão localizados em muitos *hosts*, necessitando que o gerenciamento de *log* seja executado a todo momento. Além disso, uma única fonte de *log* pode gerar vários registros, como por exemplo: um aplicativo que armazena tentativas de autenticação em um registro e atividade de rede em outro registro.
- **Conteúdos inconsistentes:** cada fonte de *log* registra certas informações em seu *log* de entradas, como endereços IP de *host* e nomes de usuário. Para eficiência, as fontes de *log* geralmente registram apenas as informações que consideram mais importantes. Isso pode dificultar o link entre

eventos registrados por diferentes fontes, pois eles podem não ter nenhum valor comum registrado (por exemplo: a fonte 1 registra o endereço IP de origem, mas não o nome de usuário. Já a fonte 2 registra o nome de usuário, mas não o endereço IP de origem). Cada tipo de fonte de *log* também pode representar valores diferentes. Essas diferenças podem ser pequenas, como uma data no formato MMDDAAAA e outra no formato DDMMAAAA, ou elas podem ser muito mais complexas, como o uso do protocolo de transferência de arquivos (FTP) sendo identificado pelo nome em um *log* ("FTP") e pelo número da porta em outro registro (21). Isso complica ainda mais o processo de vinculação de eventos registrados por fontes diferentes.

- **Timestamps inconsistentes:** cada *host* que gera *logs* normalmente faz referência a seu relógio interno ao definir um carimbo de data/hora para cada entrada de registro. Se o relógio de um *host* estiver impreciso, os carimbos de data/hora nos registros também serão incertos. Isso pode tornar a análise de registros mais difícil, especialmente quando vários *hosts* estão sendo analisados. Por exemplo, carimbos de data/hora podem indicar que o evento A aconteceu 45 segundos antes do evento B, quando, na realidade, o evento A aconteceu dois minutos após o evento B.
- **Formatos de *log* inconsistentes:** muitos tipos de fonte de *logs* usam formatos diferentes para seus registros, como arquivos de texto separados por vírgula ou tabulação, bancos de dados, *syslog*, protocolo SNMP, linguagem de marcação extensível (XML) e arquivos binários. Alguns dos registros são projetados para serem lidos por humanos, enquanto outros não, além de que alguns usam formatos padrão, enquanto outros usam formatos proprietários. Alguns são criados não para armazenamento local em um arquivo, mas para transmissão a outro sistema para processamento; um exemplo comum são os traps SNMP. Para alguns formatos de saída, particularmente arquivos de texto, existem muitas possibilidades para a sequência de valores em cada entrada de registro e os delimitadores entre os valores (por exemplo: valores separados por vírgula, valores delimitados por tabulação ou XML).

Para facilitar a análise de *logs*, as organizações muitas vezes precisam implementar métodos automatizados de conversão com registros de diferentes conteúdos e formatos. Formatos de registro e representações de campo de dados inconsistentes também apresentam desafios para as pessoas no momento de revisar os *logs*, pois elas precisam entender o significado de vários campos de dados em cada *log* para realizar uma revisão completa.

3.2 Proteção de logs

Como os *logs* contêm registros do sistema e da segurança da rede, eles precisam ser protegidos contra violações de sua confidencialidade e integridade. Por exemplo, os registros podem capturar intencionalmente dados confidenciais, como senhas de usuários e conteúdo de e-mails. Isso eleva a preocupação com a segurança e as questões de privacidade envolvendo os indivíduos que revisam os registros e outros que podem ser capazes de acessar os *logs* por meios autorizados ou não.

Segundo Chuvakin et al. (2012), a estação de análise deve ser protegida, permitindo o acesso apenas àqueles que vão trabalhar com as ferramentas, verificando as permissões de arquivo e criptografando o tráfego. Registros que são protegidos indevidamente no armazenamento ou em trânsito também podem ser suscetíveis à alteração e à destruição intencionais ou não. Isso poderia causar diversos impactos, incluindo permitir que atividades maliciosas passem despercebidas e manipular evidências para ocultar a identidade de uma parte mal-intencionada. Nesse sentido, muitos *rootkits* são especificamente projetados para alterar registros e remover qualquer evidência de instalação ou execução.

As organizações também precisam proteger a disponibilidade de seus registros. Muitos *logs* têm um tamanho máximo, como armazenar os 10 mil eventos mais recentes ou manter 100 megabytes de dados de *log*. Quando o limite de tamanho é alcançado, o *log* pode sobrescrever dados antigos com novos dados ou parar o *log* completamente, o que causaria uma perda de disponibilidade dos dados de *log*. Para atender aos requisitos de retenção de dados, as organizações podem precisar manter cópias dos arquivos de *log* por um período mais longo do que as fontes de *log* originais conseguem suportar, o que exige o estabelecimento de processos de

arquivamento. Em razão do volume de *logs*, pode ser apropriado, em alguns casos, reduzir os *logs* filtrando as entradas que não precisam ser arquivadas. A confidencialidade e a integridade dos *logs* arquivados também precisam ser protegidas.

3.3 Análise de logs

Na maioria das organizações, os administradores de rede e de sistema são os responsáveis por realizar análises de *log*, estudando entradas de *log* para identificar eventos de interesse. Porém, muitas vezes, isso tem sido tratado como uma tarefa de baixa prioridade pelos administradores, pois outras funções, como lidar com problemas operacionais e resolver vulnerabilidades de segurança, exigem respostas rápidas. De acordo com Chuvakin et al. (2012), *logs* podem mostrar com certeza que algo aconteceu.

Os administradores responsáveis por realizar a análise de *log* geralmente não recebem nenhum treinamento para fazê-lo de forma eficiente e eficaz, principalmente na priorização. Além disso, eles geralmente não recebem ferramentas eficazes na automatização de grande parte do processo de análise, como *scripts* e ferramentas de software de segurança (como produtos de detecção de intrusão com base em *host*, informações de segurança e software de gerenciamento de eventos).

Muitas dessas ferramentas são particularmente úteis para localizar padrões que os humanos não podem ver com facilidade, como entradas de correlação de vários *logs* que se relacionam ao mesmo evento. Outro problema é que muitos administradores consideram a análise de *log* cansativa, oferecendo poucos benefícios em relação ao tempo necessário para sua realização. A análise de *log* é frequentemente tratada como reativa, ou seja, algo a ser feito depois que um problema foi identificado por outros meios, em vez de proativa, para identificar atividades em andamento e procurar sinais de problemas iminentes. Tradicionalmente, a maioria dos *logs* não é analisada em tempo real ou em tempo quase real. Sem processos para analisar *logs*, seu valor é reduzido significativamente.

Em razão da complexidade do gerenciamento de *logs*, há algumas ferramentas especializadas para implementar o processamento de mensagens, incluindo o uso de inteligência artificial.

Na Tabela “Ferramentas para análise de *log*”, estão descritas algumas ferramentas tradicionais utilizadas por administradores para gerenciar informações de *log*.

Ferramenta	Descrição
Logcheck	Desenvolvida para analisar automaticamente arquivos de <i>log</i> em busca de violações de segurança e atividades não usuais. Para isso, a ferramenta utiliza uma lista de expressões regulares a fim de classificar as mensagens. É possível definir categorias como: violação do sistema, mensagens e ignorar, tentativas de comprometimento, entre outras. A ferramenta possibilita o agendamento de mensagens de <i>logs</i> (hora/dia/semana/mês), permitindo o envio das análises via e-mail.
Swatch	Semelhante ao Logcheck, mas com o diferencial de permitir disparar ações para cada evento classificado. Por exemplo, assim que diversas tentativas de conexão de um determinado IP são detectadas, uma regra de bloqueio pode ser inserida no filtro de pacotes.
OSSEC	Ferramenta de código aberto que inclui agentes para diversas plataformas, com os quais é possível receber informações de sistemas de logs, tal como o Syslog.
Splunk	Ferramenta comercial que atua como um centralizador de <i>logs</i> , na qual é possível concentrar diferentes formatos, como Syslog e Windows Event log, por exemplo, unificando as informações em uma base de dados própria. Adicionalmente, permite análises gráficas, análises forenses (<i>timeline</i>) e módulos para análise específicos para dispositivos, tal como dispositivos CISCO.

Tabela 1 – Ferramentas para análise de log
Fonte: Ceron (2014)

4 BOAS PRÁTICAS

Apesar dos muitos desafios que uma organização enfrenta no gerenciamento de *log*, existem algumas práticas recomendadas que uma organização pode seguir para evitar e até resolver muitos dos obstáculos que enfrenta. As quatro medidas a seguir fornecem uma breve explicação dessas soluções:

- **Priorize o gerenciamento de *log* de maneira apropriada em toda a organização:** recomenda-se que uma organização defina seus requisitos e objetivos para a execução de registros de monitoramento, a fim de incluir as leis, os regulamentos e as políticas organizacionais existentes. A organização pode então priorizar seus objetivos com base no equilíbrio da re-

dução de risco da organização com o tempo e os recursos necessários para executar as funções de gerenciamento de *log*.

- **Estabeleça políticas e procedimentos para gerenciamento de *log*:** políticas e procedimentos são benéficos, pois garantem uma abordagem consistente em toda a organização e asseguram que as leis e os requisitos regulamentares sejam atendidos. As auditorias periódicas são uma forma de confirmar se as diretrizes os padrões de registro estão sendo seguidos em toda a organização. O teste e a validação podem garantir ainda mais que as políticas e os procedimentos no processo de gerenciamento de *log* estejam sendo executados adequadamente.
- **Crie e mantenha uma infraestrutura de gerenciamento de *log* segura:** é muito útil para uma organização criar componentes de uma infraestrutura de gerenciamento de *log* e determinar como esses componentes vão interagir. Isso ajuda a preservar a integridade dos dados contra modificações ou exclusões acidentais ou intencionais, além de manter a confidencialidade dos registros. Também é importante criar uma infraestrutura robusta o suficiente para lidar não apenas com os volumes esperados de dados de *log*, mas também com os volumes de pico durante situações extremas (como incidente de *malware* generalizado, teste de penetração e varreduras de vulnerabilidade).
- **Forneça suporte adequado para todos os funcionários com responsabilidade de gerenciamento de *log*:** ao definir o esquema de gerenciamento de *log*, as organizações devem garantir o treinamento necessário para a equipe e oferecer as instruções e os recursos essenciais para apoiar esse gerenciamento. O suporte também inclui o fornecimento de ferramentas de análise, orientação técnica sobre atividades e disseminação de informações para a equipe responsável.

CONCLUSÃO

O gerenciamento de registros desempenha um papel crucial no processo de segurança da informação, auxiliando na detecção de incidentes de segurança, violações de políticas, atividades fraudulentas e questões operacionais, além de contribuir para auditorias e análises forenses.

O desafio das organizações é a criação de uma cultura organizacional de gerenciamento de *logs* que atenda as leis e regulamentos do mercado, com políticas organizacionais e o devido tratamento do risco. As auditorias periódicas ajudam a confirmar se as diretrizes estão sendo seguidas.

REFERÊNCIAS

CERON, J. M. **Tratamento de incidentes de segurança**. Rio de Janeiro: RNP/Escola Superior de Redes, 2014.

CHUVAKIN, A. et al. **Logging and Log Management**. Rockland: Syngress, 2012.

CLEMENTE, R. G. **Uma arquitetura para processamento de eventos de log em tempo real**. Dissertação (Mestrado em Informática) – Pontifícia Universidade Católica do Rio de Janeiro, Rio de Janeiro, 2007.

KENT, K.; SOUPPAYA, M. Guide to Computer Security Log Management. **NIST**. 2006. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf>>. Acesso em: 13 jun. 2024.

KREPS, J. **I Heart Logs**. Sebastopol: O'Reilly Media, 2014.